AI and PII:

Navigating Data Privacy Risks

in Healthcare, Fintech, and Retail



Threats, risks, and actionable defenses for responsible AI usage

Kellyn Gorman, Advocate and Engineer at Redgate Software

Kellyn Gorman

Multiplatform and AI Advocate



Session Agenda

01

Why AI Changes the PII Threat Landscape

New exposure vectors introduced by AI systems

02

Industry Deep Dives

Healthcare, Fintech, and Retail

03

Key Threat Vectors

Data leaks, re-identification, adversarial attacks, poisoning

Session Agenda (continued)

04

Mitigation Strategies

Differential privacy, federated learning, runtime controls

05

Regulatory Landscape

GDPR, CCPA, HIPAA, and the EU AI Act

06

Tooling Demo

Data protection examples across platforms



Why AI Changes the PII Threat Landscape

New risks that traditional data protection was not designed for

The AI Threat Shift: Scale and Inference



Scale

AI processes billions of data points, expanding the PII attack surface dramatically.



Inference

Models infer sensitive attributes like health or income from non-sensitive inputs.



Opacity

Black-box models make it hard to audit what PII is memorized or exposed.

The AI Threat Shift: Speed and Automation



Speed

Automated pipelines can exfiltrate or misuse PII data faster than any manual control can respond.



Automation

AI-driven decisions act at machine speed with no human review, amplifying errors and bias at scale.



Reach

Cloud-hosted AI exposes PII across jurisdictions, complicating compliance with regional data laws.

Industry Deep Dives

Healthcare, Fintech, and Retail

Healthcare: A High-Value Target



1. Medical records, patient histories, and genetic data are among the most sensitive PII categories
2. AI diagnostic tools are trained on patient cohorts, creating re-identification pathways
3. De-identified datasets can be re-combined using AI to reconstruct individual identities
4. HIPAA compliance gaps emerge when AI generates or modifies clinical outputs

Fintech: Where Data Equals Money



1. Transaction histories, credit profiles, and KYC data are high-value targets for attackers
2. Predictive AI models enable highly targeted fraud and social engineering attacks
3. Third-party AI vendors often require broad data access, creating indirect exposure
4. AI-driven lending and scoring decisions can amplify discriminatory outcomes

Retail: Volume and Velocity of PII



1. Purchase histories, payment info, and loyalty data create rich individual profiles
2. Behavioral profiling by AI recommendation engines enables re-identification at scale
3. Cross-channel data fusion links in-store, online, and mobile identities into one profile
4. Third-party recommendation engine APIs can leak customer data outside the organization



Key Threat Vectors

How AI puts PII at risk

Threat: Data Leakage and Re-identification

Data Leakage

- AI models memorize training data and can reproduce PII when queried
- LLMs have demonstrated verbatim recall of names, addresses, and credentials
- Output filtering is the primary control, but not foolproof

Re-identification

- AI can link anonymized records to real individuals using auxiliary data
- Even aggregated datasets are vulnerable when combined with public sources
- Re-identification risk grows as more data sources are merged

Threat: Adversarial Attacks and Model Poisoning

Adversarial Attacks

- Crafted inputs can trick AI systems into revealing private training data
- Prompt injection bypasses guardrails in LLM-based applications
- Membership inference attacks reveal whether specific records were in training data

Model Poisoning

- Corrupted training data biases AI decisions toward incorrect outcomes
- Poisoning can target specific demographic groups, causing discriminatory results
- Supply chain AI components are a growing attack vector

Threat: Automated Bias and Third-Party Exposure

Automated Bias

- AI decision-making amplifies existing biases in healthcare access and lending
- Biased outcomes at machine speed affect thousands before detection
- Bias in training data leads to legally discriminatory decisions

Third-Party Exposure

- AI vendors and APIs often require broad access to production PII data
- Indirect exfiltration happens through telemetry, logs, and model updates
- Vendor contracts rarely address AI-specific data handling obligations



Mitigation Strategies

A layered approach to protecting PII in AI systems

Mitigation: Data Handling Practices

1. Minimize PII in training sets using data reduction and synthetic substitution
2. Apply tokenization and field-level encryption before data enters AI pipelines
3. Enforce strict data retention and automated deletion policies across all AI datastores
4. Audit data lineage end to end before any model ingestion begins

Mitigation: Privacy-Preserving Model Design

1. Differential Privacy (DP-SGD): add calibrated noise to gradients during training so individual records cannot be inferred
2. Federated Learning: train models across devices or institutions without centralizing raw PII data
3. Privacy-preserving synthetic data generation to replace or supplement real PII in training sets
4. Data extraction safeguards and cloning techniques to test and limit memorization before deployment

Mitigation: Runtime Controls

1. Output filtering to detect and block PII before it appears in AI responses
2. Rate limiting and anomaly detection on model queries to catch bulk extraction attempts
3. Prompt injection detection and sandboxing for LLM-based applications
4. Role-based access control (RBAC) on model endpoints and API layers

Mitigation: Governance and Oversight

1. Privacy impact assessments required before any AI system touches production PII
2. Ongoing model audits to catch emerging bias and data leakage over time
3. Third-party AI vendor due diligence including contractual data handling obligations
4. Incident response plan specifically covering AI-driven data breaches and model failures



Regulatory Landscape

GDPR, CCPA, HIPAA, and the EU AI Act

GDPR: The Global Baseline

1. Right to explanation: individuals can request reasons for automated AI decisions affecting them
2. Data minimization and purpose limitation apply to every stage of AI training and inference
3. Data Protection Impact Assessments (DPIA) are required for high-risk AI processing
4. 72-hour breach notification obligation applies to AI systems handling personal data

CCPA and CPRA: California's Framework

1. Right to opt out of automated profiling and AI-based targeted advertising
2. Right to know what AI infers about individuals, including sensitive inferences
3. Data broker registration requirements extend to AI platforms handling personal data
4. Enforcement through the California Privacy Protection Agency with significant fine authority

HIPAA and AI: Healthcare's Compliance Challenge

1. Protected Health Information (PHI) cannot be used to train commercial AI without patient consent
2. Business Associate Agreements (BAA) must cover AI vendors with any access to PHI
3. Minimum necessary data standard applies to every AI pipeline touching clinical records
4. Audit logs are required for AI-assisted clinical decisions and recommendations

EU AI Act: The Emerging Global Standard

1. Classifies AI by risk level: high-risk systems in healthcare and finance require conformity assessments
2. Prohibits real-time remote biometric identification in public spaces and social scoring systems
3. Mandates transparency and human oversight for AI decisions that affect individuals significantly
4. GPAI model providers must register capabilities and comply with emerging reporting requirements

Pipeline Risk Report Demo

Python Script Logging and Risk Assessment

Can be built for any vendor or platform

Shadow AI

The Invisible Risk

You don’t know what you don’t know about

What is Shadow AI and Why Do I Care?

1. Any unauthorized AI used inside the organization’s network
2. Unauthorized embedded AI in applications that hasn’t been approved
3. Personal AI assistants, generative AI, agents, etc., both free and paid
4. Every organization I’ve been an AI Advisor for has discovered Shadow AI

Demo: MS Defender for Cloud Apps (CASB)

What the Security Broker and Reporting Does:

1. Shadow IT discovery: identify unapproved AI apps that are handling PII without oversight
2. Data classification policies that flag sensitive PII in cloud storage and AI outputs
3. Anomalous access alerting for bulk downloads and after-hours data exports

Example Report: PII Exposure in Sanctioned Cloud Apps

MS Defender Cloud Apps Report

The Data Professionals Friend

Demo: Defender for Cloud Apps (continued)

1. Session controls blocking copy and download of content classified as sensitive or PII
2. App risk scoring against GDPR and HIPAA compliance criteria for all connected cloud apps
3. Integration with DLP policies to enforce consistent data handling across sanctioned apps

These capabilities have analogues in Palo Alto Prisma, Zscaler, Netskope, and others

Three Categories:

Tier 1: CASB/SSE Leaders with Strongest Shadow AI Capabilities

Tier 2: SaaS Security Posture & Identify-Centric Tools

Tier 3: Purpose-Built AI Governance/Shadow AI Platforms

Tier 1

Netskope: Provides granular controls for orgs concerned with data exfiltration, insider threats and shadow AI/IT.

Zscaler Zero Trust Exchange: Offers ability to inspect cloud-bound traffic and apply policies that restric access to unauthorized AI services. Will detect when employees attempt to upload data to AI platforms and auto-block.

Palo Alto Networks Prisma SASE/Next Gen CASB: behavioral analytics and deep inspection of network activity. Blends network and SaaS controls.

Skyhigh Security(McAfee): Cloud-based zero trust security that is data-aware. Monitor and mitigate security risks and shadow AI discovery.

Cisco Umbrella + Cloudlock: DNS-layer protection by monitoring traffic and proactively blocking unauthorized AI domains.

Forcepoint CASB: Reports on all AI and cloud application use, including shadow AI and enforces appropriate controles based on rules.

Tier 2

Grip Security: Identify-centric SaaS risk management, let’s security teams manage API and integration surfaces. Strong discovery for AI tools employees have connected via OAuth and personal credentials CASB might miss.

DoControl: Provides app-to-app and identify-centric SaaS risk visibility, while surfacing shadow AI integrations and data flows between sanctioned and unsanctioned applications.

Obsidian Security: Focused on SaaS threat detection and response, including providing continuous visibility and analytics on unauthorized apps and shadow AI.

Tier 3

Securiti.ai: Extends into AI security and Governance with context-aware LLM firewalls to protect AI interactions including prompts, retrieval and responses. Stops shadow AI alongside other features.

Lasso Security/Protect AI: This is an emerging, purpose-built platform focused specifically on AI security, model risk, prompt injection and shadow AI usage.

Zentera: New platform positioning as dedicated shadow AI security that goes beyond what traditional CASB and SWG tools can enforce with AI.

Demo: Microsoft Intune (MDM and MAM)

Intune Capabilities:

1. Mobile Application Management (MAM) for AI apps on both enrolled and unmanaged devices
2. Data Loss Prevention policies that block PII copy-paste between managed and personal apps
3. Conditional access to block unenrolled or non-compliant devices from reaching PII datastores

Example Report: Device Compliance and PII App Access Summary

Intune Report

Data Risk Knowledge

Demo: Intune (continued)

1. App protection policies for health and financial apps to prevent data leakage at the device level

2. Compliance reporting showing which devices have access to PII data and their policy status

3. Integration with Azure AD conditional access for identity-aware PII data governance

Equivalent capabilities exist in Jamf, VMware Workspace ONE, and other MDM platforms

Actionable Recommendations

1

Immediate

- Audit all AI tools and APIs with access to PII
- Enable CASB to discover shadow AI usage
- Implement DLP policies on AI-enabled cloud apps

2

Short-Term

- Apply differential privacy to new model training
- Conduct privacy impact assessments for existing models
- Establish AI vendor due diligence checklist

3

Strategic

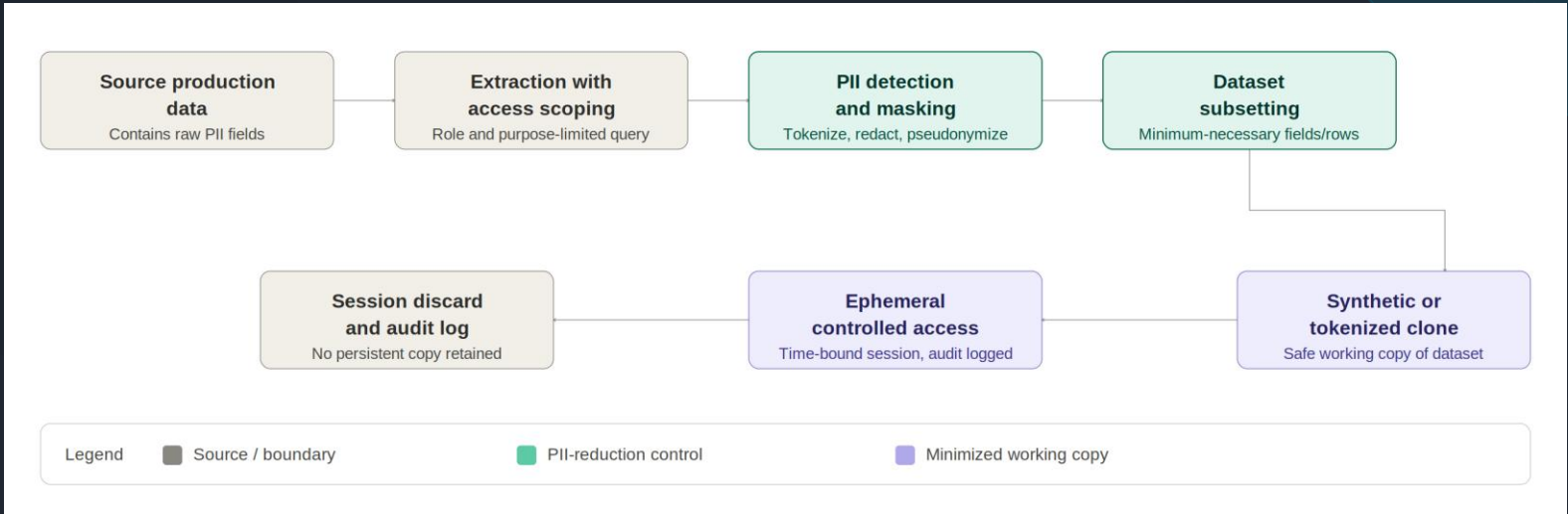
- Adopt privacy-by-design in AI development lifecycle
- Build federated learning pilots for sensitive verticals
- Align AI governance to GDPR, CCPA, and EU AI Act



Key Takeaways

- AI dramatically expands the PII threat surface across all sectors
- Threats are both technical and governance challenges; both must be addressed
- Regulatory frameworks are catching up; compliance is a floor, not a ceiling
- The tools to protect PII in AI pipelines already exist; adoption is the gap

Recommended Practices for Data Protection with AI



And Don’t Forget the Shadow AI!

It exists unless there are solutions to block it.

Questions and Discussion

Thank You!

Kellyn Gorman
Kellyn.Gorman@red-gate.com